INFORME TÉCNICO DE AUDITORÍA CRIPTOGRÁFICA
Evaluación de Cumplimiento de la Política de Contraseñas (CAI 1)

Asignatura: Seguridad en Sistemas de Información e Internet | **Equipo:** Security Team 2 (ST-2)
Autores: Raimundo García Pérez, Konstantinos Peridis, Luis Alarcón Conradi
Fecha: Septiembre de 2026 | **Código de Entrega:** ST-2-CAI1A

1. Resumen Ejecutivo

A requerimiento de la entidad financiera, el equipo de auditoría de **SecurTech Advisory** ha evaluado el nivel de robustez y cumplimiento normativo de las credenciales de acceso correspondientes a cuatro cuentas de empleados registradas en la base de datos corporativa. La entidad mantiene una Política de Seguridad que exige contraseñas con una longitud mínima de 8 caracteres y la presencia simultánea de caracteres alfabéticos (mayúsculas y minúsculas), caracteres numéricos ($0 \ldots 9$) y símbolos especiales autorizados.

A partir del extracto remitido por el cliente, se identificó el almacenamiento de resúmenes criptográficos con codificación Base64 y longitud de 256 bits (32 bytes), acompañados de valores de salting individual por cuenta. Mediante un procedimiento forense controlado que correlacionó las pistas contextuales aportadas, el equipo de consultoría logró descifrar y evaluar el 100% de las contraseñas analizadas.

Dictamen Técnico Principal: La auditoría certifica que **la totalidad de los usuarios analizados (100%) incumple la Política de Seguridad corporativa**. A pesar de que todos los empleados satisfacen el umbral de longitud mínima estipulado, ninguno de ellos reúne de forma concurrente el conjunto integral de requisitos de complejidad exigidos. Este escenario constata una brecha estructural en los sistemas de la empresa: la organización no dispone de barreras técnicas de validación activa en sus capas de registro y autenticación, supeditando la confidencialidad de los accesos a la discrecionalidad individual de los usuarios.

2. Resumen Ejecutivo de la Metodología Aplicada

Para garantizar un proceso riguroso y reproducible sin comprometer los datos de producción, la auditoría se articuló en cuatro fases operativas consecutivas:

1. **Normalización y Deducción Criptográfica:** Los resúmenes facilitados se encontraban en codificación Base64 con una extensión de 44 caracteres (32 bytes decodificados / 256 bits). Se procedió a su conversión canónica a formato hexadecimal, determinando inequívocamente el empleo de la función de dispersión segura **SHA-256**.
2. **Análisis de Esquema de Salting:** La base de datos incorporaba un campo de sal (*salt*) asignado a cada usuario. Se modeló el comportamiento del motor de autenticación evaluando tanto la disposición de la sal en modo sufijo ($Hash(Password \parallel Salt)$) como en modo prefijo ($Hash(Salt \parallel Password)$), identificando que el sistema corporativo combina ambos esquemas según la rutina de inserción.
3. **Estrategias Dirigidas de Recuperación de Credenciales:** Apoyándose en las pistas y hábitos declarados por los propios empleados, se definieron vectores de análisis optimizados:
   - *Ataque por diccionario léxico:* Rastreo en corpus lingüísticos internacionales para la identificación de vocablos inusuales.
   - *Ataque híbrido (Diccionario + Regla/Máscara):* Exploración combinada de contraseñas de alta recurrencia adosadas a delimitadores y sufijos numéricos.
   - *Ataque por máscara exhaustiva reducida:* Búsqueda acotada sobre representaciones temporales y cronológicas (fechas de nacimiento).
   - *Ataque mediante diccionario sintético a medida:* Generación programática de permutaciones nominales incorporando caracteres especiales.
4. **Verificación de Confidencialidad y Cumplimiento Normativo:** Las claves obtenidas fueron contrastadas de manera automatizada contra las directivas de la política empresarial, preservando el contenido en claro en anexos independientes.

3. Evaluación y Matriz de Cumplimiento de la Política de Seguridad

La Política de Seguridad de la entidad estipula taxativamente cuatro directivas obligatorias:

- **Regla 1 (R1):** Longitud mínima obligatoria de 8 caracteres.
- **Regla 2a (R2a):** Presencia simultánea de letras mayúsculas y letras minúsculas ($A \dots Z$, $a \dots z$).
- **Regla 2b (R2b):** Inclusión de al menos un dígito numérico ($0 \dots 9$).
- **Regla 2c (R2c):** Inclusión de al menos un símbolo especial permitido del catálogo corporativo.

Para salvaguardar la privacidad de las cuentas auditadas conforme al criterio deontológico de consultoría, los valores en texto plano se han omitido del cuerpo del informe y se desglosan en el **Anexo III**. A continuación se resume la matriz de auditoría individual:

Empleado Auditado	Salt	R1 ($\geq$8)	R2a (May./Min.)	R2b (0-9)	R2c (Símb.)	Dictamen Corporativo
Luis Toreman Gerto	40	CUMPLE (15)	INCUMPLE	INCUMPLE	INCUMPLE	INCUMPLE POLÍTICA
Ana Pearse Sanz	51	CUMPLE (11)	INCUMPLE	CUMPLE	CUMPLE ('.')	INCUMPLE POLÍTICA
Pedro Marteis Poncio	18	CUMPLE (8)	INCUMPLE	CUMPLE	INCUMPLE	INCUMPLE POLÍTICA
Arturo Ruiz Gasca	31	CUMPLE (17)	INCUMPLE	INCUMPLE	CUMPLE ('*')	INCUMPLE POLÍTICA

Cuadro 1: Matriz de auditoría sobre el cumplimiento de la Política de Seguridad de contraseñas.

3.1. Diagnóstico Individualizado de Infracciones

- **Luis Toreman Gerto (Salt:** `40`**):**
  - **Cumple:** Únicamente satisface la longitud formal requerida (15 caracteres alfabéticos).
  - **Infracciones:** Vulnera severamente las reglas **R2a** (solo contiene letras minúsculas), **R2b** (carece de dígitos) y **R2c** (carece de símbolos).
  - **Diagnóstico:** Se limitó a seleccionar un vocablo de diccionario sin aportar entropía complementaria.
- **Ana Pearse Sanz (Salt:** `51`**):**
  - **Cumple:** Satisface la longitud (11 caracteres), la presencia numérica (**R2b**) y la presencia de símbolo (**R2c**, mediante punto).
  - **Infracciones:** Vulnera frontalmente la regla **R2a** (omite completamente el uso de caracteres alfabéticos).
  - **Diagnóstico:** Patrón predecible consistente en una secuencia numérica consecutiva seguida de delimitador y sufijo.
- **Pedro Marteis Poncio (Salt:** `18`**):**
  - **Cumple:** Alcanza el umbral de longitud mínima estricta (8 caracteres) y contiene caracteres numéricos (**R2b**).
  - **Infracciones:** Vulnera las reglas **R2a** (sin caracteres alfabéticos) y **R2c** (sin símbolos especiales).
  - **Diagnóstico:** La credencial reproduce exactamente una fecha en formato canónico ($DDMMAAAA$), siendo fácilmente deducible mediante ingeniería social.
- **Arturo Ruiz Gasca (Salt:** `31`**):**
  - **Cumple:** Sobresale en extensión (17 caracteres) e integra símbolos delimitadores (**R2c**, mediante asteriscos).
  - **Infracciones:** Vulnera las reglas **R2a** (ausencia total de letras mayúsculas) y **R2b** (ausencia de dígitos numéricos).
  - **Diagnóstico:** Composición nominal evidente derivada directamente de los apellidos y el nombre de pila del propio empleado.

4. Conclusiones Técnicas y Recomendaciones

4.1. Conclusiones de la Auditoría

1. **Eficacia del Algoritmo SHA-256 vs. Debilidad del Modelo de Entrada:** La adopción de SHA-256 con salting individual representa una mejora frente a funciones obsoletas (MD5 o SHA-1). Sin embargo, la robustez criptográfica resulta inútil si las entradas carecen de entropía o si el sistema acepta contraseñas triviales.
2. **Ausencia de Validación Técnica Activa:** Ninguna de las cuatro cuentas fue rechazada durante su configuración. La Política de Seguridad actual opera como una mera declaración formal sin fuerza ejecutiva en el software de la empresa.
3. **Predecibilidad Basada en Factores Humanos:** Todos los empleados recurrieron a mnemotecnias predecibles (términos de diccionario, fechas familiares o nombres propios), neutralizando la protección aportada por la sal criptográfica.

4.2. Recomendaciones de Seguridad (Técnicas y Organizativas)

1. **Implementación de Filtros Técnicos Previos (Pre-Validation Hooks):** Integrar en los módulos de backend rutinas estrictas de verificación que impidan la creación de credenciales que incumplan cualquiera de las directivas de la política (véase propuesta técnica en el Anexo V).
2. **Revisión y Estandarización del Mecanismo de Salting:** Garantizar que la sal se genere mediante generadores pseudoaleatorios criptográficamente seguros (CSPRNG), con longitud recomendada superior a 16 bytes y concatenación consistente en toda la base de datos.
3. **Adopción de Funciones de Derivación de Claves (Key Stretching):** Evolucionar desde SHA-256 simple con sal hacia algoritmos con factor de coste de trabajo (*work factor*) como PBKDF2, bcrypt o Argon2id para mitigar ataques masivos de fuerza bruta.
4. **Mecanismos de Autenticación Complementaria (MFA / Biometría):** Desplegar esquemas de verificación en dos pasos (TOTP / FIDO2) para desacoplar la seguridad del sistema de un único factor estático.

5. Propuesta de Servicios de Consultoría: SecurTech Advisory

Ante las vulnerabilidades estructurales identificadas, la firma consultora **SecurTech Advisory** ofrece a la entidad financiera un plan integral de remediación técnica y organizativa:

- **Auditoría Integral de Gestión de Accesos e Identidades (IAM):**
  - Análisis forense y saneamiento del censo corporativo de credenciales para purgar claves débiles o comprometidas.
  - Reestructuración de la base de datos para estandarizar la política de salting y funciones de derivación seguras.
- **Despliegue de Módulos de Validación y Control en Capa de Aplicación:**
  - Integración de microservicios de validación previa en los formularios de registro y restablecimiento de claves.
  - Implementación de medidores de entropía visuales y advertencias automáticas ante el uso de nombres y fechas personales.
- **Implantación de Doble Factor de Autenticación (MFA) y Gobernanza:**
  - Puesta en marcha de autenticación multifactor mediante aplicaciones corporativas o llaves de seguridad física.
  - Programas de capacitación y concienciación periódica contra ingeniería social dirigidos a la plantilla.

6. Bibliografía

- Ceballos Guerrero, Rafael. *Tema 2: Integridad de la Información (Partes 1 y 2)*. Grupo de Investigación Quivir, Dpto. Lenguajes y Sistemas Informáticos, Universidad de Sevilla.
- Documentación oficial y manual de referencia de **Hashcat** (v7.x): modos de ataque, optimización OpenCL y configuración de hashes con sal: `https://hashcat.net/wiki/`.
- Hashcat Example Hashes and Hash-Type Mapping Directory: Catálogo de referencia técnica para correlación de algoritmos criptográficos y factores de dispersión según longitud de cadena y esquema de salting (`-m 1410`, `-m 1420`): `https://hashcat.net/wiki/doku.php?id=example_hashes`.

7. Relación de Anexos Entregados

Junto al presente informe de consultoría, el equipo auditor adjunta un paquete de evidencias digitales compuesto por los siguientes artefactos:

- **Anexo I: Script de Decodificación Criptográfica (`b64_to_hex.py`):**
  - Módulo en Python 3 para transformar los resúmenes en Base64 suministrados por el cliente a cadenas hexadecimales de 256 bits, generando los ficheros canónicos de entrada para Hashcat (`hash:salt`).
- **Anexo II: Script Generador de Diccionario Sintético (`generador_arturo.py`):**
  - Script programado para modelar y sintetizar el espacio de búsqueda léxico a partir de combinaciones de nombres, apellidos y caracteres de separación especificados en las pistas.
- **Anexo III: Registro de Contraseñas Recuperadas en Claro (`soluciones.txt`):**
  - Documento de acceso restringido que certifica los hashes auditados, sus sales correspondientes y las contraseñas en claro recuperadas durante la auditoría.
- **Anexo IV: Memoria Metodológica Detallada de Auditoría (`metodologia_ejecucion.pdf`):**
  - Documento en formato PDF que expone el entorno informático de prueba (Kali Linux), configuración del backend OpenCL de CPU, modos de ataque ejecutados y comandos completos de consola de Hashcat utilizados en cada caso.
- **Anexo V: Módulo de Validación de Contraseñas en PHP (`validador_password.php`):**
  - Demostración técnica de una rutina en PHP de validación previa en backend que intercepta e impide el almacenamiento de contraseñas no conformes con la Política de Seguridad, propuesta como primera fase de remediación.

Informe emitido en Sevilla por SecurTech Advisory para la Entidad Financiera. Todos los derechos reservados.